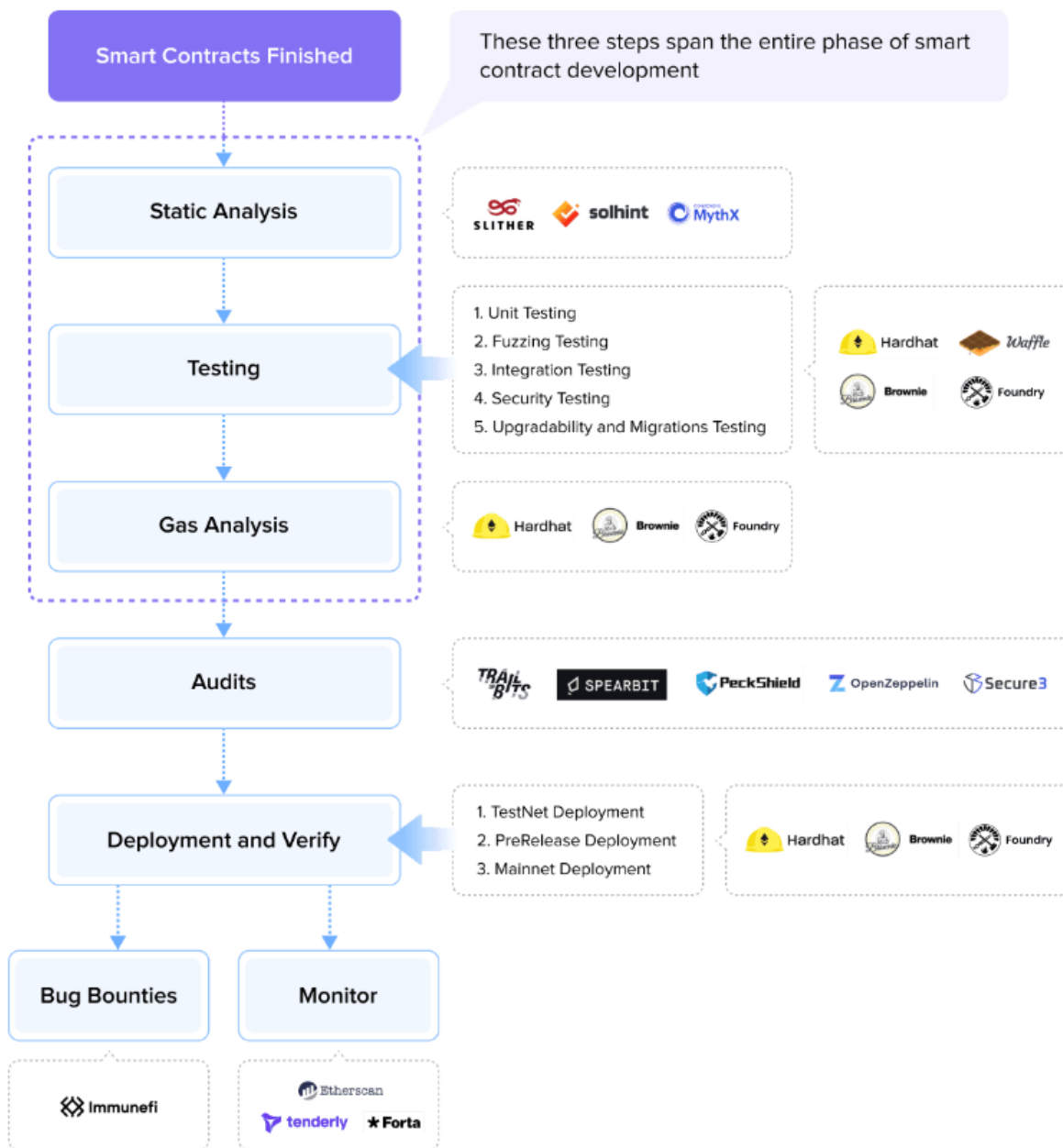


合约安全管理

合约安全管理流程:



安全监控平台

有相当一部分漏洞只有在部署了以后才能被找到，而利用漏洞往往需要多笔异常交易才能完成。监控系统能够在一系列的异常交易中刚完成第一笔或者第二笔时发出警报，那将会为项目减少巨额损失并且帮助团队修复该漏洞。

使用监控工具或平台可以全面了解智能合约的风险和行为，通过检测威胁、获取威胁和异常警报，并自动响应和解决问题。

目前市面上主流的几款产品:

- Openzeppelin Defender
- Forta

- Tenderly

Openzeppelin Defender

是为区块链应用编码、审计、部署、监控和操作提供全流程管理的安全平台

代码检查:

与 Github 无缝集成, 通过由机器学习和openzeppelin的安全专家开发的工具提供支持的自动代码分析。

可以在合约开发完成后, 使用defender的代码检查进行扫描 (或设置PR时自动扫描) 并生成报告。

Update Solidity Version

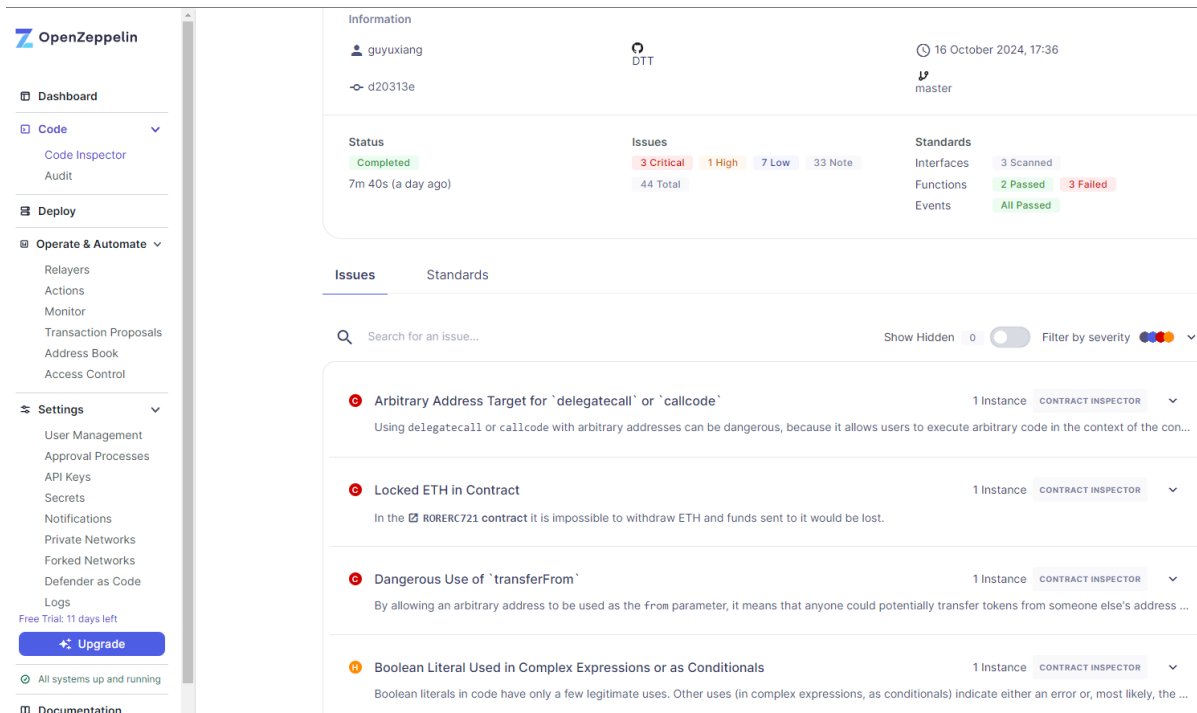
Generated at commit: [df528127f12e75e7cd6a688e0d68b7c34e2bd719](#)



Report Summary

	Severity Level	Results
Contracts	<i>Critical</i>	3
	<i>High</i>	1
	<i>Medium</i>	0
	<i>Low</i>	7
	<i>Note</i>	32
	Total	43
Dependencies	<i>Critical</i>	0
	<i>High</i>	0
	<i>Medium</i>	0
	<i>Low</i>	0
	<i>Note</i>	0
	Total	0

For more details view the full report in [OpenZeppelin Code Inspector](#)



主动漏洞检查功能：在openzeppelin安全团队发现新的漏洞时自动再次扫描代码库，当检测到新漏洞时会自动发送邮件通知和建议。

合约实现ERC协议接口标准的检查：比如使用的是 `IERC20`，代码检查器将检查合约实现函数和属性，以确保您正确使用此 ERC。

监视器：

在defender平台上配置好区块链网络、合约地址、ABI后，可以指定过滤规则，对合约函数或事件的参数进行匹配，当匹配到链上行为后发出通知

支持设置多个监视器监控不同行为，并设置不同风险等级，还可以设置不同的通知方式、通知内容、警报阈值、警报间隔

付费用户还可以对匹配到的结果再进行更复杂的自定义脚本过滤

自动化操作：

使用javascript 编写链上和链下操作的自定义应用逻辑，并在条件满足后触发进行自动化操作，同时 defender可以存储管理私钥，在自动化操作代码中可以加载私钥并签名，触发方式如下

- 时间：设置频率后定时触发
- 监视器：由 Defender监视器触发，包含触发事件的上下文可以在操作代码中读取使用
- Webhook：Defender 将为该操作创建一个 webhook URL，被调用后触发

权限的监督和管理：

defender平台可以对权限合约进行监控，配置合约地址后识别权限合约的角色和成员地址，每分钟与合约进行一次链上同步，可以在平台上使用管理员角色对权限进行修改。

交易审批：

重要操作如升级、暂停、修改配置操作，可提前配置好交易提案和审批流程，审批通过后才能执行交易。

优势：

在于平台集成性强，专为智能合约运维而设计，方便管理和安全检查。

Forta

Forta Network 是一个去中心化的安全监控网络，由OpenZeppelin 团队内部一个团队开发并独立出来已获得 2300 万美元的融资，该网络的由监控机器人（docker）、监控节点（服务器）、用户组成，实现去中心化的对链上活动的安全和运营监控，目前也已集成到openzeppelin defender中，可以使用Forta替代原生的监控系统。

项目方可以订阅现有的监控机器人（目前已有几千个开源机器人），也可以使用forta-sdk 自行编写监控机器人来进行一系列自定义监控，然后可以部署在节点运营商或者本地节点，这些节点会运行机器人进行监控，其他项目方或用户也可以付费使用公开的监控机器人，运行节点不断扫描每个区块中所有交易数据，当扫描节点中的告警机器人匹配到数据中的特定条件或事件时，就会发出警报，警报将会储存在IPFS 上，任何人可以通过 Forta Explorer 或者 API 订阅相关警报。

无许可的去中心化激励模式：

Forta利用\$FORT 代币激励来吸引监控节点运营商和监控机器人开发者加入该网络，运行监控节点和开发机器人需要质押代币获取安全性，同时可以获得代币激励，监控机器人使用者支付代币给节点和机器人开发者。

机器学习：

开发者可以在告警机器人中使用机器学习模型，利用机器学习来预测攻击者行为。

研报：

<https://foresightnews.pro/article/detail/15049>

优势

自定义监控机器人灵活性更强，可以执行更具复杂的监控，如多笔业务关联交易联合监控、跨链场景多交易监控。

Tenderly

是一个智能合约开发和调试平台，提供监控、模拟、调试和报警功能。

监控+Web3 Actions：

Tenderly同样也可以监控链上合约的行为和事件，并在事件发生时将实时通知。

通过编写自定义的TypeScript/JavaScript脚本, 实现一些自动化的操作，还带有键值存储，用于存储需要保留的数据，和监控报警一起使用，监控事件触发后，执行Web3 Actions指定的JavaScript/TypeScript代码，立即处理该事件。

优势

在于该平台可以进行调试和模拟，开发者在监控过程中进行详细的错误排查和性能分析。

使用体验

推荐使用OpenZeppelin Defender+Forta的组合，使用Defender平台进行运维，使用Forta搭建本地节点和开发监控机器人进行免费且业务定制的安全监控。

监控场景

目前想到的可以对我们项目监控报警的行为

- **交易失败：**用于及早发现我们系统的使用问题，可更早发现bug而不是由用户报告。
- **合约升级：**监控合约升级操作，如果发现不合常理的升级操作，可能意味着有人试图通过升级篡改合约逻辑以进行攻击。
- **合约所有权转换：**监控合约所有权变化，发现黑客行为。
- **治理监控：**监控治理合约上的新提案、状态变化或投票活动。
- **访问控制变更：**监控权限合约中的某些重要角色的变化如issue，可能代表合约遭到攻击或恶意操纵。
- **货币余额达到阈值：**监控充值账户的余额，可以了解何时需要充值。
- **交易价值达到阈值：**监控超出我们业务场景可能的最大值的大额交易，可能意味着私钥被盗或合约被黑。
- **系统外调用者或调用系统外合约交互：**可能是黑客在测试我们的合约，提前发现黑客行为。
- **ERC20 或者ERC721代币转移：**比如监控到代币转移到了一个系统外陌生地址。

- **频繁的交易操作**：如果短时间内发生了大量的交易请求，可能是恶意攻击者正在尝试执行重复操作，利用漏洞（如重入攻击）窃取资金。
- **资金池余额异常变化**：对于资金池类的合约，持续监控其余额变化，如果在短时间内出现急剧下降，可能是恶意攻击者利用了某个漏洞来转移资金。
- **合约暂停监控**：如果监控到合约执行了暂停操作，尤其是在没有提前公告的情况下，需要立刻报警，因为这可能是合约遭遇严重攻击或内部故意操作。
- **Gas使用量异常**：如果某笔交易的Gas消耗异常高或者明显超过了正常的操作范围，可能意味着合约中存在逻辑漏洞，攻击者正在利用复杂的计算或高资源消耗操作试图中断合约或耗尽网络资源。
- **合约存储数据异常修改**：智能合约通常存储重要的变量或状态数据，如果监控到合约的存储数据被异常修改，比如关键参数（如Suspense地址等）被非正常方式更改，可能是攻击者绕过了合约的正常逻辑进行操作。
- **异常的流动性操作**：针对流动性池的合约，监控流动性池的注入和移出操作是否符合预期，如果出现大规模的资金提取或注入（尤其是单一地址），可能预示着合约漏洞被利用或流动性危机。
- **合约调用栈深度异常**：智能合约执行时有调用栈深度限制，如果监控到合约调用栈过深（例如在递归调用中），这可能表明攻击者试图利用合约中的递归调用漏洞进行攻击。
- **异常Token发行或销毁操作**：如果合约涉及Token发行或销毁的操作，当检测到异常的大量Token发行或销毁时，可能是合约漏洞被利用或是内部行为恶意操作。
- **密钥泄露和授权异常检测**：监控我们系统的部署或者管理账户地址的系统外合约交易，可能发送了密钥泄露或授权账户异常地扩展权限，需要立即发出警报，防止进一步的资金或合约操作被恶意执行。

自动化操作响应

根据不同等级的报警，自动执行不同策略响应

- **暂停合约**：可以立即停止资金转移或其他敏感操作，防止进一步的损失。
- **限制恶意账户的权限**：限制或冻结账户权限可以有效防止攻击者进一步操作合约。
- **触发自动回滚（Revert）操作**：检测到异常操作后，自动触发回滚，将合约状态恢复到攻击前的状态。
- **启用时间锁机制**：防止快速执行的恶意操作，给系统和管理员更多时间来做出反应。
- **转移资产至安全地址**：自动将合约中的资产转移到预先设置的冷钱包或安全地址。
- **自动回购或赎回机制**：针对资金池类合约，当检测到借贷池或流动性池面临风险时，自动触发回购或赎回机制，锁定流动性。

事件响应计划模板：

[项目名称] 事件响应计划

立即措施

- ☐ **审查漏洞交易以识别漏洞 - [负责人]**
 - 使用工具：
 - [blocksec交易浏览器](#)
 - [Tenderly 调试器/交易重放模拟](#)
- ☐ **暂停合约，采取其他防御措施，考虑进攻性措施（如白帽救援） - [协调负责人]**
 - 步骤：
 - **[谁、如何、哪些地址]**
 - 审查交易 - [负责人，应与创建交易的人不同]
 - 不要在紧急时刻慌乱地去找谁能签署防御行动。建议使用 [OpenZeppelin Defender](#)，并提前准备好防御行动脚本，能够根据[预发布安全检查清单](#)部署。
- ☐ **审查所有合约以识别潜在连锁漏洞。必要时暂停这些合约 - [负责人]**
- ☐ **更新UI以反映当前状态 - [负责人]**
- ☐ **联系安全合作伙伴 - [负责人]**
 - **[列出过去的审计员及其联系方式或共享频道的位置]**
 - 您的审计员会希望在能力范围内协助，即便是主要为了保护他们自己的声誉
 - 不要让任何外部人员进入您的核心信任圈
 - 即使攻击者成功转移了资金，也不要假设被盗资金不可追回。立即联系可信赖的合作伙伴，包括已知的安全专业人员或您的风险投资者，寻求相关执法机构、资产追踪专家和恢复服务的推荐。
- ☐ **通过相关社交媒体渠道通知用户。Discord: - [负责人]，Twitter: - [负责人]**
 - 随着有意义的新信息或进展定期更新
 - 即使没有新的信息，至少每24小时更新一次，这将帮助安抚社区，表明您正在处理问题
 - 所有消息应由漏洞审查员审查，以确保不会无意中泄露会影响安全的细节，或在事实不明确时承诺具体补救措施

完成立即措施后

- ☐ **起草并发布完整的公开事件后报告 - [负责人]**
- ☐ **为合约准备补丁，最好遵循[开发流程](#)的指南 - [负责人]**
 - ☐ 让过去的审计员审查并签署补丁
 - ☐ 由尽可能多的可信团队成员和社区成员审查补丁
 - ☐ 如果补丁或潜在的交互足够复杂，强烈建议进行短期的 [Code4rena](#) 竞赛（可在48小时内启动）
- ☐ **部署补丁（升级合约） - [负责人]**